

**НЕКОММЕРЧЕСКОЕ АКЦИОНЕРНОЕ ОБЩЕСТВО
«КАЗАХСКИЙ НАЦИОНАЛЬНЫЙ ПЕДАГОГИЧЕСКИЙ
УНИВЕРСИТЕТ ИМЕНИ АБАЯ»**



УТВЕРЖДЕНО

Решением Правления
НАО «Казахский национальный
педагогический университет
имени Абая»

от «19» августа 2025 года

Протокол №
Председатель Правления - Ректор
Тілеп Б.



**Правила организации процедуры аутентификации и разграничения
прав доступа к электронным информационным ресурсам
Некоммерческого акционерного общества «Казахский национальный
педагогический университет имени Абая»**



Оглавление

1 Общие положения.....	3
2 Нормативная основа.....	4
3 Правила организации аутентификации.....	4
4 Порядок смены паролей.....	5
5 Хранение паролей.....	5
6 Процедуры разграничения прав доступа.....	5
7 Ответственность	6
Приложение 1.....	7
Приложение 2.....	8
Лист согласования.....	9

1 Общие положения

1.1 Настоящие Правила аутентификации и разграничения прав доступа ИТ инфраструктуры (далее — Правила) Некоммерческого акционерного общества «Казахский национальный педагогический университет имени Абая» (далее — Университет) разработаны в соответствии с требованиями законодательства и стандартов Республики Казахстан в области информационной безопасности.

1.2 Цель настоящих правил — установление четких процедур и стандартов для управления аутентификацией, разграничением прав доступа и учетными записями в информационной инфраструктуре Университета, с целью обеспечения безопасности данных, защиты от несанкционированного доступа и оптимизации работы всех пользователей в рамках учебного и административного процессов.

1.3 В настоящих Правилах используются следующие основные термины и определения:

Информационная система (далее — ИС) — организационно-упорядоченная совокупность информационно-коммуникационных технологий, обслуживающего персонала и технической документации, реализующих определенные технологические действия посредством информационного взаимодействия и предназначенных для решения конкретных функциональных задач;

Учетная запись — набор данных, который используется для аутентификации пользователя в информационной системе, включая логин и пароль, а также дополнительные параметры безопасности (например, двухфакторную аутентификацию);

Аутентификация — процесс подтверждения подлинности пользователя с целью предоставления ему доступа к информационным системам и ресурсам;

Разграничение прав доступа — процесс определения и контроля прав пользователей на доступ к различным информационным ресурсам в зависимости от их должностных обязанностей и уровня полномочий;

Двухфакторная аутентификация (2FA) — метод аутентификации, при котором для получения доступа к системе пользователю необходимо предоставить два независимых элемента подтверждения (например, пароль и одноразовый код, отправленный на мобильное устройство);

Active Directory — централизованная система управления учетными записями и правами доступа пользователей в сети;

Удаление учетной записи — процесс аннулирования учетной записи пользователя в информационных системах и блокировки его доступа к университетским ресурсам;

Восстановление пароля — процесс, при котором пользователю предоставляется возможность сбросить забытый пароль и получить доступ к своей учетной записи.

2 Нормативная основа

Настоящий документ разработан в соответствии со следующими нормативно-правовыми актами и документами:

- Постановление Правительства Республики Казахстан от 20.12.2016г. №832 «Об утверждении единых требований в области информационно-коммуникационных технологий и обеспечения информационной безопасности»;
- СТ РК ИСО/МЭК 27002-2009 «Информационные технологии. Средства обеспечения. Свод правил по управлению защитой информации»;
- СТ РК ИСО/МЭК 27001-2008 «Информационная технология. Методы и средства обеспечения безопасности. Системы управления информационной безопасностью».

3 Правила организации аутентификации

3.1 Учетные записи сотрудников создаются вручную в системе Active Directory системным администратором. Для каждого сотрудника назначается уникальный логин и пароль, которые предоставляются в рамках его должности и функциональных обязанностей.

3.2 Учетные записи для студентов и преподавателей создаются в системе Univer.

3.3 Пароль должен состоять минимум из 8 символов.

3.4 В числе символов пароля обязательно должны присутствовать буквы в верхнем и нижнем регистрах, цифры и/или специальные символы (% , \$, @ , & , * , # , ^ и так далее), в том числе вводимые через клавишу Shift.

3.5 Пароль не должен содержать личную информацию пользователя, включая фамилию, имя, отчество (полностью или частично); дату рождения или иные персональные данные (например, номер телефона, адрес).

3.6 Пароль не должен содержать простых слов, таких как "password", "admin", "123456", "qwerty" и т.д.

3.7 Запрещается при авторизации пользователя использовать только логин (имя пользователя) без пароля.

3.8 Запрещается выбирать пароли, которые уже использовались ранее.

3.9 Для доступа к особо критически важным виртуальным серверам внедрена двухфакторная аутентификация, основанная на одноразовых кодах, которые генерируются с помощью приложений-аутентификаторов (Microsoft Authenticator или Google Authenticator).

3.10 В случае увольнения сотрудника учетная запись удаляется вручную системным администратором из Active Directory.

3.11 В случае отчисления студент теряет доступ ко всем образовательным ресурсам и системам, и его учетная запись удаляется из системы Univer.

4 Порядок смены паролей

4.1 Все пользователи должны менять пароли не реже чем раз в 30 дней. Пользователь, администратор информационной системы имеют возможность смены пароля в любое время.

4.2 Системный администратор определяет политику смены пароля, предусматривающую срок действия пароля не более девяносто календарных дней выдачи предупреждающего сообщения о необходимости смены пароля и блокировки доступа к информационным ресурсам по истечению срока действия пароля.

4.3 Пользователь осуществляет смену паролей учетных записей до истечения их срока действия.

4.4 При смене пароля новое значение должно отличаться от предыдущего не менее чем в 6 позициях.

4.5 В случае блокировки пароля пользователь может задать новый пароль:

- студенты должны обратиться непосредственно к своему эдвайзеру, который инициирует процесс восстановления доступа;
- сотрудники должны обратиться к системному администратору, который проводит процесс сброса пароля.

Идентификация пользователя проходит с использованием фотографии его удостоверения личности.

5 Хранение паролей

5.1 Пользователям запрещается сообщать другим пользователям личный пароль и регистрировать их в системе под своей учетной записью и паролем.

5.2 Пароли администраторов информационных систем с именами учетных записей и датой установки паролей хранятся у Офицера информационной безопасности.

6 Процедуры разграничения прав доступа

6.1 Доступ к ИС в Университете предоставляется на основании заявки на предоставление доступа к ней, в соответствии с Приложением 1 к настоящим Правилам.

6.2 При регистрации пользователя ему назначается роль, которая строго ограничивает доступ пользователя к ИС.

6.3 С целью соблюдения принципа персональной ответственности за свои действия, каждому сотруднику, который имеет доступ к работе в ИС присваивается персональное уникальное имя (учетная запись пользователя) с паролем.

6.4 Лицам, не прошедшим регистрацию в ИС, доступ к ресурсам ИС не предоставляется.

6.5 Если сотрудник уволился или его должностные обязанности изменились, его права доступа обновляются или удаляются.

6.6 Системные администраторы ведут Журнал регистрации пользователей (в электронном виде), согласно приложению 2 к настоящим Правилам. В журнале фиксируются все пользователи и их права доступа.

7 Ответственность

Пользователи обязаны следить за безопасностью своих учетных записей и соблюдать требования по установке и использованию двухфакторной аутентификации для повышения уровня защиты.

Офицер информационной безопасности отвечает за обеспечение контроля за внедрением и соблюдением этих правил сотрудниками и подразделениями, а также за обеспечение регулярного аудита учетных записей пользователей и их прав доступа.

Системные администраторы несут ответственность за создание и своевременное удаление учетных записей для сотрудников, восстановление доступа при необходимости.

Руководители подразделений обязаны уведомлять отдел Управления информационных технологии о любых изменениях в составе сотрудников, а также о случаях увольнения или перевода, которые требуют удаления или изменения учетных записей.

Приложение 1
к Правилам аутентификации и
разграничения прав доступа к
электронным ресурсам

Заявка
на предоставление/закрытие/изменение доступа к ИС Университета

В связи с производственной необходимостью прошу Вас:

- создать
- изменить
- блокировать учетную запись.

(Отметить необходимое действие)

Ответственное структурное подразделение	Руководитель (Ф.И.О. (при его наличии) структурного подразделения	Подпись	Дата

п\п	Фамилия, имя, отчество (при его наличии)	Должность	Подпись	Дата

Контактное лицо: _____

Е-mail контактного лица: _____

Телефон контактного лица: _____

Приложение 2
к Правилам аутентификации и
разграничения прав доступа к
электронным ресурсам

Журнал регистрации пользователей

№ п/п.	Ф.И.О. (при его наличии)	Ответственное структурное подразделение	Должность	Адрес, телефон	Адрес электронной почты	Уровень доступа

ЛИСТ ОЗНАКОМЛЕНИЯ

[illegible]

Алматы, 2025